

# Interest-Free Online Banking System

**Owner:** Cybersecurity Threat Modeling Lab  
**Reviewer:**  
**Contributors:**  
**Date Generated:** Sat May 16 2026



OWASP Threat Dragon

# Executive Summary

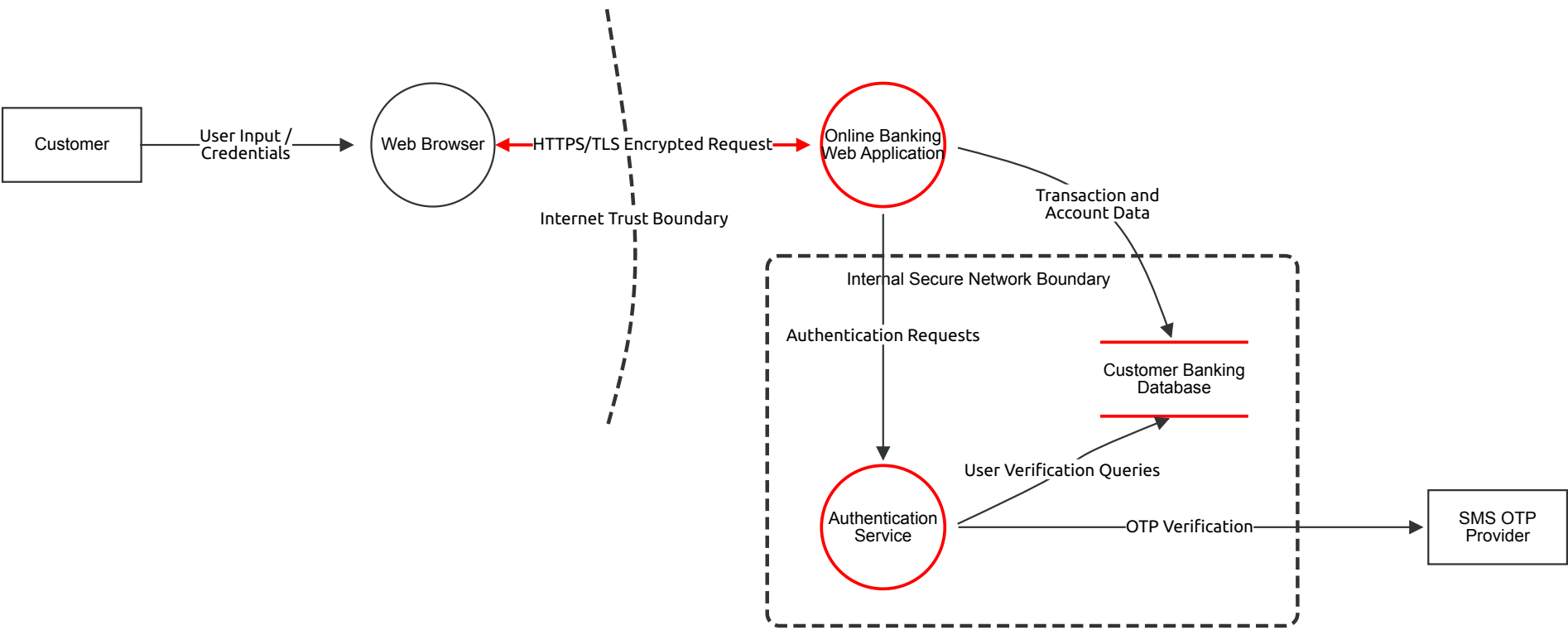
## High level system description

Threat model assessment for an online banking platform using the STRIDE methodology and OWASP Threat Dragon.

## Summary

|                          |   |
|--------------------------|---|
| Total Threats            | 9 |
| Total Mitigated          | 0 |
| Total Open               | 9 |
| Open / Critical Severity | 3 |
| Open / High Severity     | 5 |
| Open / Medium Severity   | 1 |
| Open / Low Severity      | 0 |

# Online Banking STRIDE Threat Model Architecture



# Online Banking STRIDE Threat Model Architecture

## Customer (Actor)

| Number | Title | Type | Severity | Status | Score | Description | Mitigations |
|--------|-------|------|----------|--------|-------|-------------|-------------|
|--------|-------|------|----------|--------|-------|-------------|-------------|

## Web Browser (Process)

| Number | Title | Type | Severity | Status | Score | Description | Mitigations |
|--------|-------|------|----------|--------|-------|-------------|-------------|
|--------|-------|------|----------|--------|-------|-------------|-------------|

## Online Banking Web Application (Process)

| Number | Title                       | Type              | Severity | Status | Score | Description                                                                                                                                                 | Mitigations                                                                                                               |
|--------|-----------------------------|-------------------|----------|--------|-------|-------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------|
| 4      | Automated Transaction Abuse | Tampering         | High     | Open   |       | See OWASP Automated Threat #6: Using speed to violate explicit or implicit assumptions about the application’s normal use to achieve unfair individual gain | Defences include providing enforcement of behavioral workflow and anti-automation                                         |
| 6      | Denial of Service           | Denial of service | Critical | Open   |       | See OWASP Automated Threat #15: Usage may resemble legitimate application usage but leads to exhaustion of resources                                        | Mitigation or prevention such as providing backoff, resource management and avoiding forced deadlock                      |
| 15     | Transaction Repudiation     | Repudiation       | Medium   | Open   |       | Users may deny performing banking transactions if sufficient audit logging and transaction tracking are not implemented.                                    | Enable audit logging, transaction timestamps, centralized log monitoring, and secure transaction verification mechanisms. |

## Customer Banking Database (Store)

| Number | Title                          | Type                   | Severity | Status | Score | Description                                                                                                                                                                                | Mitigations                                                                                                      |
|--------|--------------------------------|------------------------|----------|--------|-------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------|
| 7      | Scraping                       | Information disclosure | High     | Open   |       | See OWASP Automated Threat #11: Collecting accessible data and/or processed output from the application                                                                                    | Detect fake or compromised accounts, ensure information is accessible only with authentication and authorisation |
| 8      | Transaction Manipulation Abuse | Elevation of privilege | Critical | Open   |       | See OWASP Automated Threat #16: Automated repeated clicking or requesting or submitting content, affecting application based metrics such as counts, and measures of frequency and/or rate | Defences include control of interaction frequency or proper enforcement of a single unique action                |

## SMS OTP Provider (Actor)

| Number | Title | Type | Severity | Status | Score | Description | Mitigations |
|--------|-------|------|----------|--------|-------|-------------|-------------|
|--------|-------|------|----------|--------|-------|-------------|-------------|

## Authentication Service (Process)

| Number | Title                  | Type                   | Severity | Status | Score | Description                                                                                                                                              | Mitigations                                |
|--------|------------------------|------------------------|----------|--------|-------|----------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------|
| 11     | Vulnerability scanning | Information disclosure | High     | Open   |       | See OWASP Automated Threat #14: Systematic enumeration and examination in order to find weaknesses and points where a security vulnerability might exist | Defence includes providing anti-automation |

| Number | Title               | Type              | Severity | Status | Score | Description                                                                                                             | Mitigations                                                                                                                    |
|--------|---------------------|-------------------|----------|--------|-------|-------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------|
| 12     | Denial of Service   | Denial of service | Critical | Open   |       | See OWASP Automated Threat #15: Usage may resemble legitimate application usage but leads to exhaustion of resources    | Mitigation or prevention such as providing backoff, resource management and avoiding forced deadlock                           |
| 14     | Credential Spoofing | Spoofing          | High     | Open   |       | Attackers may impersonate legitimate users using stolen credentials, phishing attacks, or session hijacking techniques. | Implement multi-factor authentication (MFA), strong password policies, account lockout controls, and login anomaly monitoring. |

## User Input / Credentials (Data Flow)

| Number | Title | Type | Severity | Status | Score | Description | Mitigations |
|--------|-------|------|----------|--------|-------|-------------|-------------|
|--------|-------|------|----------|--------|-------|-------------|-------------|

## Authentication Requests (Data Flow)

| Number | Title | Type | Severity | Status | Score | Description | Mitigations |
|--------|-------|------|----------|--------|-------|-------------|-------------|
|--------|-------|------|----------|--------|-------|-------------|-------------|

## HTTPS/TLS Encrypted Request (Data Flow)

| Number | Title                    | Type                   | Severity | Status | Score | Description                                                                                                                                | Mitigations                                                                          |
|--------|--------------------------|------------------------|----------|--------|-------|--------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------|
| 16     | Data Interception Attack | Information disclosure | High     | Open   |       | Sensitive banking information may be intercepted during transmission through insecure communication channels or man-in-the-middle attacks. | Enforce HTTPS/TLS encryption, certificate validation, and secure session management. |

## User Verification Queries (Data Flow)

| Number | Title | Type | Severity | Status | Score | Description | Mitigations |
|--------|-------|------|----------|--------|-------|-------------|-------------|
|--------|-------|------|----------|--------|-------|-------------|-------------|

## OTP Verification (Data Flow)

| Number | Title | Type | Severity | Status | Score | Description | Mitigations |
|--------|-------|------|----------|--------|-------|-------------|-------------|
|--------|-------|------|----------|--------|-------|-------------|-------------|

## Transaction and Account Data (Data Flow)

| Number | Title | Type | Severity | Status | Score | Description | Mitigations |
|--------|-------|------|----------|--------|-------|-------------|-------------|
|--------|-------|------|----------|--------|-------|-------------|-------------|